PENSE-BÊTE · RAPPORT ET STRATÉGIE

# Cyberattaques DGFiP 2026

00-10 ANSSI - Rapport d'incident sur les cyberattaques ayant touché la DGFiP (2026) — source : fiche de révision du module (gemma4, 03/11/2026)

**À RETENIR**

1. Zerobytes revendique le 12 août 678 437 enregistrements volés via **E-Contact** (exfiltration du 24 juin, 7 semaines avant).
2. L'attaquant a utilisé le RIE pour pivoter depuis le ministère de l'Éducation nationale.
3. Le vol de données cadastrales a été rendu possible par le contournement de la double authentification sur le portail APEX.

## Synthèse du rapport et des faits

| Notion | À retenir |
|---|---|
| Rapport de transparence | Rapport **n°3033** de l'**ANSSI** (**23 septembre 2026**) ; **20 pages** ; anonymisé (ex: `compte-dgfip` + numéro). |
| Revendication Zerobytes | Revendiquée le **12 août 2026** (impots.gouv.fr) ; données **E-Contact** : près de **353 000** particuliers et **252 000** professionnels ; **678 437** enregistrements annoncés. |
| Données cadastrales | Revendication du **13 août** (**SPDC**, **2 millions** de Français évoqués) ; poste d'un **géomètre-expert** compromis, double authentification **APEX** contournée ; **27 juillet – 8 août**. |
| Attaque non détectée | Exfiltrations non détectées par la **DGFiP** ou l'**ANSSI** ; exploitation de faiblesses : **identité**, **architecture** et **détection**. |

## Déroulement de l'attaque

| Notion | À retenir |
|---|---|
| Vol d'identifiants | Plusieurs dizaines d'identifiants volés sur **3 mois** via des `infostealers` sur des **appareils personnels** (non administrés). |
| Exploration | **2-8 mai** : un compte se connecte au **PIGP** depuis 3 localisations (IP **France**, **Inde**) ; **22 mai - 3 juin** : autres comptes, mêmes IP, sans alerte. **7 juin** : passage au portail **ADER**, non vu. |
| Pivot ministériel | Utilisation du **RIE** via des infrastructures du **ministère de l'Éducation nationale**. Alerte du **COSSIM** le **9 juin** avec **17 marqueurs techniques**. |
| 1ère exfiltration | Exfiltration **E-Contact** du **24 juin 4 h 26** au **25 juin 2 h 31** ; mot de passe réinitialisé le **24 juin à 10 h 40** sans couper la session. **11 Go** échangés du **22 au 25 juin**, sans alerte. |
| 2ème exfiltration | **22 juillet** : exfiltration automatique sur **E-Contact** ; recherches suspectes détectées le **23 juillet** (compte réinitialisé), IP bloquée le **24 juillet** ; **3 Go** échangés. |
| Endiguement | **6 août** : l'**ANSSI** signale 2 IP malveillantes ; **11 août** : blocage et **5 comptes** réinitialisés. Coupures définitives : **ADER** le **13 août**, **PIGP** (comptes agents) le **18 août**. |

## Enseignements de l'attaque DGFiP

| Notion | À retenir |
|---|---|
| Compromission comptes | Accès via identifiants volés sur applications exposées. **Absence d'authentification multifacteur** sur **PIGP** et **ADER** ; code par courriel sur **APEX** insuffisant. |
| Détection comportements | Échec de corrélation des signaux (**volume données**, **requêtes**, **IP suspectes**, **connexions nocturnes**). **SOC DGFiP** ne supervisait pas le portail **ADER**. |
| Filtrage segmentation | Segmentation trop permissive. Accès **RIE** depuis des lieux sans besoin métier. Nécessité d'un **filtrage plus fin des flux** entre ministères. |
| Supervision ANSSI | Pas de **supervision applicative** ; la **supervision réseau** ne repère pas des connexions faites avec des comptes légitimes ; le **volume de requêtes** aurait dû alerter. |
| Coordination interministérielle | Délai d'analyse/partage des **marqueurs techniques** (via **RIE**) trop long. Blocage des flux au **RIE** nécessite une **cartographie des flux légitimes**. |

## Mesures de remédiation de la DGFiP

| Notion | À retenir |
|---|---|
| Accès ressources métiers | Usage interne : postes administrés **DGFiP** et **VPN** réservé. Usage externe limité : réseaux internes, **VPN** partenaires ou **IP autorisées**. Usage public : filtrage géographique et **IP mal réputées**. |
| Protection identifiants | Proscrire les appareils personnels. Appareils professionnels durcis (**mises à jour mensuelles**, **EDR**, **antivirus**, **VPN** actif). Déployer l'**authentification multifacteur** (jeton physique ou application). |
| Réinitialisation compte | Accompagner de l'**analyse de l'activité** depuis la compromission. Révoquer les **sessions actives**. Rechercher la **cause racine** en cas de compromission répétée. |
| Plan d'action | Trois axes : **supervision** applications métiers, **limiter l'exposition** identifiants (**authentification forte**) et **réduire la surface d'attaque** (seuils applicatifs). |

## Pièges et confusions

- ⚠ Confondre l'application E-Contact (messagerie usagers) avec le portail APEX (partenaires externes).
- ⚠ Croire que le SOC DGFiP supervisait le portail ADER.
- ⚠ Penser que la réinitialisation du mot de passe le 24 juin à 10 heures 40 a stoppé l'exfiltration.
- ⚠ Confondre le RIE (réseau interministériel) avec le PIGP (portail de gestion publique).
- ⚠ Croire que le code envoyé par courriel sur APEX suffisait comme second facteur.

## Sigles et définitions

| | |
|---|---|
| **ANSSI** | Autorité nationale en matière de cybersécurité. |
| **DGFiP** | Direction générale des Finances publiques, victime des actes malveillants. |
| **RIE** | Réseau interministériel de l'État reliant les ministères entre eux. |
| **PIGP** | Portail internet de la gestion publique pour les ordonnateurs et comptables. |
| **Infostealer** | Logiciel malveillant conçu pour voler discrètement des données comme les identifiants. |
| **Exfiltration** | Sortie illégitime de données hors du système d'information de la victime. |
| **SOC** | Centre opérationnel de sécurité chargé de surveiller, détecter et traiter les incidents. |

## Auto-test

1. Quel est le numéro du rapport de l'ANSSI ?
2. Combien de Français la revendication sur le cadastre évoque-t-elle ?
3. Quelle entité a émis une alerte le 9 juin avec 17 marqueurs techniques ?
4. Quelle application a été la cible des deux vagues d'exfiltration ?
5. À quelle date le portail PIGP a-t-il subi une coupure définitive ?

Réponses : **1.** 3033 · **2.** 2 millions · **3.** Le COSSIM · **4.** E-Contact · **5.** Le 18 août

À compléter par la fiche, le podcast et le quiz du module. Rédigé à partir de la fiche de révision ; seuils et chiffres à la date de la source.